

2017 Equifax Breach

IS4234 Governance, Regulation, and Compliance Technology
Group 1

Name	Student Number
See Man Teng	A0281514J
Chantel Ong	A0281721J
Tania Foo Kai Ying	A0286447N
Phang Shi Yin, Nicole	A0281658R
Keith Tan Beng Hui	A0278169L

Table Of Contents

1. Introduction **4**
- 1.1 Case and Organisational Context 4
- 1.2 Research question 4
- 1.3 Contribution and Structure 4

2. Case Background **5**
- 2.1 Equifax and technology environment 5
- 2.2 Incident chronology 5
- 2.3 Governance, regulatory and control environment 6
- 2.4 Consequences and Stakeholder Response 6

3. Critical GRC Analysis **7**
- 3.1 Governance and Oversight Failure 7
- 3.2 Ownership and accountability failure 7
- 3.3 Understanding and applicability failure 8
- 3.4 Enforcement and escalation failure 9
- 3.5 Verification and evidence failure 9
- 3.6 Regulatory and external environment 9
- 3.7 Effectiveness of Equifax's Post-Breach Response 10
- 3.8 Summary of Root Causes and its Governance Issues 11

4. Recommendations **12**
- 4.1 Strengthen ownership and accountability 12
- 4.2 Formalise regulatory/security change management 12
- 4.3 Introduce risk-based escalation 12
- 4.4 Strengthen evidence-based closure 13
- 4.5 Strengthen board and executive oversight 13

5. Existing Solutions and the Market Gap **14**

6. PoliBridge: Technology-Enabled Solution **15**
- 6.1 Design Principle and Objectives 15
- 6.2 Users, decisions and ownerships 15
- 6.3 Conceptual architecture and information flow 16
- 6.4 How Requirements Enter the System 16
- 6.5 Distinctive Feature 1: Scope-Checked Evidence 17
- 6.6 Distinctive Feature 2: Evidence Decay 17
- 6.7 Distinctive Feature 3: Canary Self-Tests 17
- 6.8 Impact Classification and Decision Rules 17
- 6.9 Replaying March 2017 18
- 6.10 Value to Equifax 18

7. Evaluation, Feasibility, and Limitations **18**
- 7.1 Evaluating Effectiveness 18
- 7.2 Feasibility 19
- 7.3 Limitations and unintended consequences 19

8. Future Trends and Conclusion **20**
- 8.1 Future regulatory/GRC trends 20
- 8.2 Conclusion 21

References **22**
Appendices **24**
Appendix A — March 2017 Replay Through PoliBridge 24
Appendix B — Impact Classification Criteria 24
Appendix C — Decision Rules 25
Appendix D — RACI / approval matrix 27
Appendix E — Approved-Source Registry Schema 27
Appendix F — RAG Prompt and Output Schema 27
Appendix G — Prototype Screenshots 27
Appendix H — Test Scenarios and Results 27
Appendix I — AI-use acknowledgement 27

1. Introduction

1.1 Case and Organisational Context

Equifax Inc. is a major consumer reporting agency (CRA) whose business depends on collecting, processing and supplying large volumes of consumer information. It held personally identifiable information (PII) used for credit reporting and identity verification, including services provided to U.S. federal agencies. Congressional investigators therefore identified Equifax as having a heightened responsibility to safeguard the information entrusted to it (U.S. House of Representatives, Committee on Oversight and Government Reform [House Oversight Committee], 2018).

In 2017, attackers exploited a known vulnerability in Apache Struts within Equifax's internet-facing consumer dispute portal. Equifax had a 48-hour patching policy and had received notification of the vulnerability, yet the warning did not reach the administrator responsible for the affected application, and Equifax's scans did not detect the vulnerable component (House Oversight Committee, 2018). The incident exposed the personal information of approximately 147.9 million U.S. consumers (U.S. Government Accountability Office [GAO], 2018).

The case reflects an organisational GRC problem rather than a purely technical patching failure. A known security requirement was never translated into accountable and verifiable action. More specifically, at three points Equifax relied on a recorded status that had stopped being true: that the right owners had been notified, that the portal was not affected, and that its network traffic was being inspected. Nothing in Equifax's processes detected that these statuses had become false.

1.2 Research question

This report addresses the following research question:
How can a technology-enabled GRC system ensure that current and applicable requirements reach the correct operational owners, are understood and acted upon, and produce an auditable response that remains trustworthy over time?
The question focuses on the gap between the existence of governance and compliance requirements and their effective execution, and on whether the evidence that a requirement has been met can still be relied on after it is recorded.

1.3 Contribution and Structure

Commercial GRC and vulnerability-management platforms already route tasks to owners, monitor controls continuously and trace requirements to evidence (Section 5). Our contribution is PoliBridge, a GRC system that treats every compliance status as a claim: it must be supported by evidence that covers its specific scope, it expires when that evidence ages, and the system regularly tests its own routing and escalation. Section 2 sets out the case, Section 3 analyses its governance failures, Section 4 makes recommendations, Section 5 assesses existing solutions, Section 6 presents PoliBridge, Section 7 evaluates it and Section 8 concludes.

2. Case Background

2.1 Equifax and technology environment

By 2017, Equifax operated a complex estate of modern and legacy applications. One of these was its internet-facing consumer dispute portal, part of the Automated Consumer Interview System (ACIS), which relied on Apache Struts. ACIS was supported by several operational teams and depended on accurate asset, software and ownership information for vulnerability management. Security advisories had to be matched to affected technologies, routed to the relevant owners and tracked through remediation, so Equifax's 48-hour patching policy depended as much on reliable asset visibility, communication channels and ownership records as on technical controls.

2.2 Incident chronology

7–9 March 2017: notification and failed remediation. The Apache Software Foundation disclosed CVE-2017-5638, a critical remote-code-execution vulnerability in Apache Struts, and released a patch. On 8 March, the U.S. Computer Emergency Readiness Team notified Equifax (GAO, 2018). On 9 March, Equifax's Global Threat and Vulnerability Management team circulated the alert by email and instructed recipients to patch within 48 hours. The distribution list was outdated and did not include the ACIS administrator, so the vulnerability remained unpatched (House Oversight Committee, 2018).

15 March 2017: failed verification. Equifax's scans failed to detect the vulnerable Struts installation. An earlier component scan examined the root directory rather than the subdirectory containing Struts, and scans of 958 external-facing IP addresses on 15 March also missed it (House Oversight Committee, 2018). Running a scan did not establish that the relevant component had been checked.

13 May–July 2017: exploitation and undetected exfiltration. Attackers exploited the unpatched portal on 13 May, installed web shells, obtained unencrypted credentials that gave access to databases beyond ACIS, and ran thousands of queries (GAO, 2018). An expired SSL certificate on the device that inspected ACIS traffic meant encrypted outbound traffic could not be inspected, so exfiltration continued undetected for more than two months (House Oversight Committee, 2018).

29 July–7 September 2017: detection and disclosure. Equifax renewed the certificate on 29 July, detected suspicious traffic and took ACIS offline the next day (GAO, 2018). It engaged Mandiant, notified the FBI and disclosed the breach publicly on 7 September, initially estimating 143 million affected U.S. consumers, later revised to approximately 147.9 million (Equifax Inc., 2017; GAO, 2018).

The chronology shows failures at several stages of one control process. A remediation requirement existed but did not reach the correct owner; when remediation failed, verification did not detect it; and a separate monitoring failure allowed the intrusion to continue. Gaps in communication, accountability, verification and monitoring compounded to turn a known, manageable vulnerability into a major cybersecurity and regulatory event.

2.3 Governance, regulatory and control environment

At the time of the breach, Chief Security Officer Susan Mauldin reported through the legal function to General Counsel John Kelley, while the Chief Information Officer separately oversaw IT operations. Congressional investigators found that this structure hindered coordination and the communication of cybersecurity risk to senior management, and that board oversight relied on information channelled through management (House Oversight Committee, 2018).
Equifax was also subject to overlapping regulatory requirements. Section 5 of the Federal Trade Commission Act prohibited unfair or deceptive practices; the Gramm-Leach-Bliley Act (GLBA) Safeguards Rule required covered financial institutions, including relevant CRAs, to maintain safeguards for customer information; and state breach-notification laws varied across the United States (House Oversight Committee, 2018). In the United Kingdom, Equifax Ltd was subject to the Data Protection Act 1998. Formal policies and obligations existed, but without clear ownership, communication and verification they did not translate into operational action.

2.4 Consequences and Stakeholder Response

The breach harmed a broad range of stakeholders whose interests were interconnected: weaknesses in Equifax's cybersecurity controls affected consumer privacy, investor confidence, regulatory compliance and the company's reputation.

Shareholders and Investors: Equifax's share price fell sharply after the 7 September 2017 disclosure, reflecting investor concern over its security practices and legal exposure. The company later agreed to a global settlement of at least US$575 million, potentially rising to US$700 million (Federal Trade Commission [FTC], 2019). The incident also raised questions about whether the board and senior management had exercised adequate oversight of material cybersecurity risk.

Consumers and the Public: Consumers were the most directly affected group. The personal information of approximately 147.9 million U.S. consumers was exposed, creating risks of identity theft and fraud (U.S. Government Accountability Office [GAO], 2018). Unlike shareholders, who could sell their investments, consumers had no way to prevent the exposure or control how their data was later used.

Regulators and Government Agencies: In the United States, the FTC, Consumer Financial Protection Bureau and state authorities reached a global settlement with Equifax in 2019 (FTC, 2019). In the United Kingdom, the Information Commissioner's Office fined Equifax Ltd £500,000 for failures affecting up to 15 million UK residents (ICO, 2019). Congressional investigators also examined the organisational and technical failures behind the incident (U.S. House of Representatives, Committee on Oversight and Government Reform [House Oversight Committee], 2018).

Employees and Organisational Leadership: The Chief Information Officer and Chief Security Officer retired shortly after disclosure, followed by Chief Executive Officer Richard Smith later that month (Equifax Inc., 2017). Attributing the breach solely to individuals, however, would overlook the organisational conditions that allowed the vulnerability to remain unpatched and the intrusion to go undetected.

Commercial Customers and Government Clients: Businesses and government agencies relied on Equifax's credit and identity-verification services. The breach damaged their confidence in those

services, showing how weak controls in one organisation can undermine trust across the institutions that depend on its data.
Overall GRC Implications: The breach shows that cybersecurity is an enterprise governance responsibility, not an isolated technical function. Effective GRC requires security and regulatory requirements to be translated into clearly assigned responsibilities, enforceable controls and verifiable outcomes. When these mechanisms fail, the harm extends beyond the organisation to every stakeholder that depends on it.

3. Critical GRC Analysis

The Equifax breach arose not from a single technical failure, but from a combination of governance, accountability, compliance and control weaknesses. At the root, there was fragmented oversight, unclear ownership of critical systems, weak translation of external requirements into operational actions, ineffective escalation, and insufficient verification that controls had actually been performed. These weaknesses were compounded by a complex regulatory environment and legacy technology.

3.1 Governance and Oversight Failure

Equifax's failure began at the governance level. The organisation did receive the Apache Struts advisory, but it lacked a reliable process to ensure that critical security information was identified, escalated and assigned to the correct operational owner. The warning was distributed through an outdated mailing list, and there was no effective mechanism to confirm that the relevant team had received or acted on it. The Apache vulnerability thus could not be fixed because it was not made visible to the relevant personnel.

This reflected broader weaknesses in oversight and accountability. Equifax's security leadership did not have a strong direct reporting line to the board, while ACIS operated as a legacy system without clear ownership. These weaknesses undermined both first-line risk ownership by business units and second-line oversight by compliance and risk committees, contrary to the Three Lines of Defence model, which expects business units to own operational risk and risk/compliance functions to provide effective oversight (PwC, 2017).

Board and senior-management oversight was also insufficient. Boards should monitor management, oversee regulatory compliance, and ensure that significant risks receive appropriate attention. Equifax's fragmented information channels and weak change-monitoring practices meant that a known critical vulnerability was not surfaced as a sufficiently urgent enterprise risk as seen in section 2. From a COSO perspective, this indicates weaknesses in information and communication, internal controls and monitoring activities: relevant information was not reliably communicated to accountable parties, and control deficiencies were not escalated effectively. The lack of oversight from senior executives also sent the message to stakeholders that security and internal controls is not a priority, causing stakeholders to also take a lax stance on governance. This governance failure is the root cause from which the subsequent process failures (visibility, ownership, understanding, enforcement and verification) emerged.

3.2 Ownership and accountability failure

Equifax's vulnerability-management process relied too heavily on generic responsibility rather than clearly assigned ownership. Although the Apache Struts alert was circulated internally, the outdated

mailing list did not include the administrator responsible for the affected application. As a result, the obligation to patch existed, but there was no reliable identification and link between the requirement and a named accountable owner. This reflects a breakdown in asset ownership and accountability.

Under the Three Lines of Defence model, business units should own the risks arising from the systems and processes for which they are responsible, while risk and compliance functions provide oversight. In Equifax's case, unclear ownership of ACIS meant that responsibility for remediation could diffuse across teams rather than sit with a clearly accountable system owner.

A stronger arrangement would require explicit RACI-style allocation: a named owner responsible for remediation, supporting teams clearly identified, and a designated authority accountable for escalation when deadlines are missed (Institute Project Management, 2026). Such a framework ensures that project tasks are mapped to the correct person, minimising ambiguity and ensuring that projects can progress. Without this, overdue remediation remains unresolved because no individual is clearly answerable for completion.

The weakness was therefore not simply that the wrong person missed an email; it was that Equifax lacked a governance mechanism to map each critical obligation to a named owner, track acceptance of responsibility, and escalate non-action to management. This directly contributed to the wider failure to ensure that known obligations reached the correct accountable owner.

3.3 Understanding and applicability failure

Receiving a regulatory requirement or security advisory is insufficient if operational teams cannot determine whether it applies to their system and what action is required. In the case of Equifax, generic security information, such as the Apache patch, had to be translated into application-specific obligations, yet weak asset ownership and fragmented organisational information made that translation unreliable.

This is also a compliance-function responsibility. Compliance should identify applicable laws, maintain an obligations map, interpret requirements for business units, and communicate their criticality and required controls. Equifax was subject to overlapping requirements including the FTC Act, GLBA and state breach-notification laws, increasing the need for clear applicability assessment across systems, data and jurisdictions.

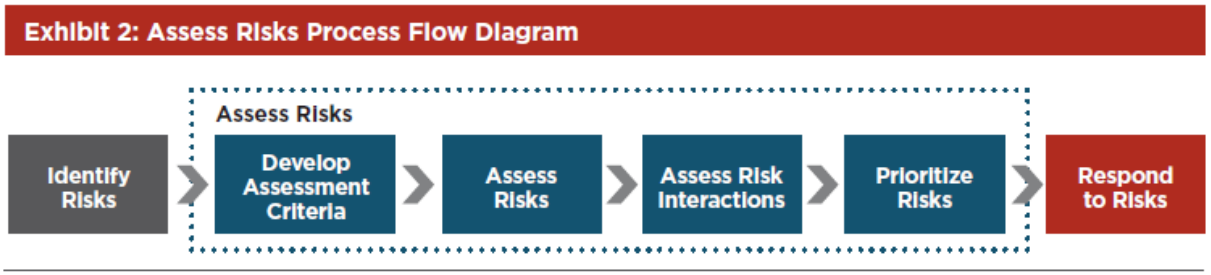
The FTC alleged that Equifax failed to provide reasonable and appropriate security for the massive volume of sensitive Personally Identifiable Information (PII), as it did not patch the critical vulnerability in its system when a critical vulnerability in its Apache Struts framework was flagged in March 2017. Hence, it is deceptive towards consumers, as Equifax publicly represented to consumers and business clients that it maintained robust security controls, strict administrative protections, and encrypted sensitive customer data.

Equifax violated the GLBA by failing to comply with the FTC's Safeguards Rule (16 C.F.R. Part 314), which requires financial institutions to maintain a comprehensive information security program to protect the confidentiality, integrity, and security of customer non-public personal information (eCFR, 2002). Equifax failed to maintain an accurate inventory of its IT assets, which prevented automated scans from locating the vulnerable Apache Struts software running on its portal.

3.4 Enforcement and escalation failure

Equifax's process largely treated notification as if it were enforcement. The Apache Struts advisory was circulated, but there was no mandatory acknowledgement, tracked task, or control ensuring that the 48-hour remediation deadline was actually met. When action was missed, escalation to management was ineffective. This is significant from a GRC perspective because compliance requires controls that prevent, detect, monitor and resolve non-compliance.

Equifax also lacked a clear and effective mechanism for formal risk identification and acceptance. If remediation could not be completed within the required timeframe, the residual risk should have been explicitly assessed, accepted by an authorised risk owner, and escalated where necessary. Instead, missed action could persist without a documented management decision.



3.5 Verification and evidence failure

Equifax also failed to verify that remediation had actually occurred. A patching policy is only effective if completion can be demonstrated through reliable evidence such as vulnerability scans, patch records, system logs, or test results. In Equifax's case, there was no reliable mechanism to confirm that the affected system had been successfully remediated.

This represents a failure of control operating effectiveness rather than merely control design. Effective controls require monitoring and evidence that they are functioning as intended; weaknesses in monitoring can leave control failures undetected.

3.6 Regulatory and external environment

Equifax operated within a fragmented regulatory environment in which cybersecurity and breach-notification obligations were spread across the FTC Act, GLBA and differing state laws. The Safeguards Rule in force in 2017 was deliberately flexible and risk-based, requiring financial institutions to maintain an information-security programme appropriate to their size, complexity and data sensitivity, but leaving substantial discretion over how safeguards were implemented (Equifax Report, 2018). In Equifax, formal policies existed, yet weaknesses in ownership, patch verification and monitoring persisted without effective intervention. At the same time, the absence of a uniform federal breach-notification regime meant disclosure obligations varied across jurisdictions, increasing compliance complexity once the breach was discovered.
Subsequent regulatory developments indicate that these gaps were recognised. In 2021, the FTC amended the Safeguards Rule to retain its risk-based approach while introducing more prescriptive cybersecurity requirements, including clearer expectations around risk assessment, access controls, monitoring and security-program governance (Federal Trade Commission, n.d.). A separate 2023

amendment, effective May 2024, introduced a federal requirement for covered financial institutions to notify the FTC within 30 days of certain breaches affecting at least 500 consumers (Federal Trade Commission, 2024). These reforms suggest a shift from broad principles towards stronger minimum controls, reporting and accountability.

The Equifax incident also exposed weaknesses relative to accepted cybersecurity practice at the time. Congressional investigators identified outdated systems, unclear lines of authority, an expired monitoring certificate and inadequate control execution, ultimately concluding that the breach was entirely preventable (Equifax Report, 2018). Existing security and GRC processes had therefore failed to connect identified vulnerabilities with affected assets, accountable owners, verified remediation and management oversight.

3.7 Effectiveness of Equifax's Post-Breach Response

Following the 2017 breach, Equifax undertook a multi-year security and technology transformation. The changes can be grouped against the failure categories identified above.

Equifax restructured its security reporting line. Jamil Farshchi joined in February 2018 as Chief Information Security Officer, reporting directly to the new CEO, Mark Begor (Equifax, n.d.). This replaced the pre-breach arrangement in which the CSO reported to the Chief Legal Officer after attending an incident management conference call (Equifax Report, 2018). Board oversight was also strengthened: four new directors joined the board, the CISO now briefs the board regularly on cybersecurity and transformation progress, and the CISO developed a Board Cyber Audit Framework of programmatic and operational metrics, targeting the filtering of security information through management that congressional investigators criticised (Begor, 2019).

Equifax adopted a unified Security and Privacy Controls Framework. Its five core capabilities (cybersecurity, privacy, fraud prevention, crisis management and physical security) are mapped to the NIST Cybersecurity Framework and Privacy Framework, acting as the basis for nearly every subsequent security and privacy improvement. Accountability was also built into incentives. All bonus-eligible employees have a security performance measure in their annual incentive compensation, and every employee receives a monthly security scorecard (Naraine, 2023). Proxy filings show that security goals, set by the Security Department according to each employee's role and responsibilities, form part of non-financial goals worth up to 20% of the annual incentive opportunity (Naraine, 2023). Unlike the generic responsibility that existed in 2017, this creates personal consequences for security outcomes.

The 2019 FTC settlement imposed that Equifax must designate an employee to oversee its information security programme, conduct annual risk assessments with safeguards such as patch-management and remediation policies, obtain annual board (or subcommittee) certification of compliance with the order, and test and monitor the effectiveness of its safeguards. In addition, it must obtain third-party assessments of the programme every two years, with the FTC approving each assessor. Board certification makes directors personally answerable for compliance, a notable change from the pre-breach position (SDM, 2019).
Equifax created the Equifax Cloud™, replacing much of the legacy estate of which ACIS was part of. The company reports that more than 150 automated security checks in its cloud environment provide real-time visibility into its security posture. Its 2025 Security Annual Report adds AI-enabled controls: AI triage agents auto-resolved nearly half of Security Operations Center tickets with a mean

time to detect under one minute, custom AI analyses vulnerabilities and drafts remediation code, and evaluation gates automatically test every new AI agent (Equifax, 2026).

However, despite this remediation, the public evidence is weighted towards aggregate outcomes: posture ratings, maturity scores, ticket-resolution rates and threats blocked. These measure the overall health of the programme. They do not show that each individual obligation is traceable end to end. Equifax's disclosures do not show how a specific advisory or regulatory requirement is mapped to affected assets, assigned to a named owner who acknowledges it, escalated when overdue, formally risk-accepted when it cannot be met, and closed only on verifiable evidence.

The post-breach response is therefore best assessed as materially stronger but incomplete from a GRC perspective. Equifax has transformed its governance structure, incentives and technical capability, but its public disclosures provide limited evidence of an integrated, auditable link between individual obligations and their accountable closure. This residual gap provides the rationale for PoliBridge, which is designed to complement Equifax's existing investments by adding explicit obligation-level ownership, governance decision rules and auditable control closure.

3.8 Summary of Root Causes and its Governance Issues

What happened	Root cause	Governance issues	Implemented solutions	PoliBridge Control Safeguard
Patch alert sent to an outdated mailing list, so the ACIS admin never received it	No link between advisory, asset and owner	Unclear ownership; no enforcement or escalation	Partial: security goals in bonuses and scorecards. FTC patch-policy requirement. Doesn't solve owner routing or acknowledgement.	Active Directory Fallback Routing, Automated Escalation & Canary Self-Tests
Scans missed the vulnerable Struts component	Inaccurate asset inventory; scan coverage not verified	No verification or closure evidence; GLBA breach	Largely solved: Equifax Cloud with 150+ automated checks; FTC-mandated testing and biennial assessments. Closure still not evidenced per obligation.	Three-State Applicability & Scope-Checked Evidence
Attackers exploited the portal and used plaintext credentials to reach other databases	Unpatched system; unencrypted credentials	No formal risk acceptance; FTC Act deception	Technical fix: least-privilege access management, code scanning, NIST-aligned controls framework. Doesn't solve risk acceptance.	Automated Risk Acceptance Workflow & Expiry
Expired SSL certificate let exfiltration go	Monitoring tooling not maintained	Weak monitoring; no	Partial: AI-driven SOC with detection in under 1 minute. Doesn't	Evidence Decay & Continuous Control Monitoring

undetected for 2+ months		owner for tooling	solve certificate or tooling ownership.	
CSO reported via legal; board got filtered information	Fragmented oversight	Weak board oversight and tone from the top	Solved structurally: CISO reports to CEO; Board Cyber Audit Framework; annual board certification. Board metrics remain aggregate.	Automated Escalation to CISO/Board & Audit Trail Dashboard
Disclosure complicated by differing state and UK laws	No obligations map	Weak applicability assessment; regulatory fragmentation	Partial: crisis management in controls framework; 2021/2024 FTC rule changes. No internal obligations-to-owner map	Obligations Mapping Engine & Automated Regulatory Intake

4. Recommendations

The following recommendations address the gaps in Section 3. Controls addressing the accountability and remediation failures that left ACIS unpatched are given immediate priority.

4.1 Strengthen ownership and accountability

Equifax should assign a named business and technical owner to every critical application and control, recording these in an asset register that links systems to software components, data, and RACI allocations. Mapping every security and compliance obligation to a specific owner aligns with the Three Lines of Defence principle and COSO guidelines for assigning clear accountability.
To prevent stale records, owners must re-attest ownership at least bi-annually, consistent with CIS Controls v8 Safeguard 1.1 v8 and regulatory standards like the FTC's amended Safeguards Rule (16 C.F.R. § 314.4(c)(2)) and NYDFS regulations (23 NYCRR § 500.13). Re-attestation should also trigger after major system or organizational changes.

Addresses: Section 3.2 (ownership and accountability failure)
Responsible stakeholders: CIO, CISO, business-unit heads and application owners.
Priority: Immediate, because unclear ownership directly contributed to the failure to remediate ACIS.

4.2 Formalise regulatory/security change management

Equifax should establish a formal four-step process:

1. Monitor regulatory sources (FTC, state laws, settlement obligations, overseas rules like UK data protection) and security advisories (US-CERT/CISA alerts, vendor notices).
2. Assess applicability by jurisdiction, data type, and technology stack.
3. Translate material changes into system-specific requirements with defined actions and required evidence.
4. Record changes in a central obligations register, map them to assets and controls, assign owners, and track implementation.

Translating changes is crucial under principle-based regulation. In 2017, Equifax partially translated the Safeguards Rule into a 48-hour patching policy but lacked links to named owners, deadlines, and completion evidence which step 4 provides. This process also incorporates newer requirements, such as the 2021 encryption, MFA, and monitoring controls and the 2023 30-day notification rule, relieving teams from identifying changes manually.

Addresses: Sections 3.3 (understanding and applicability) and 3.6 (regulatory environment)
Responsible stakeholders: Compliance, Legal, Information Security and Technology Risk.
Priority: Near term, followed by longer-term automation of regulatory-change monitoring and obligation mapping.

4.3 Introduce risk-based escalation

Critical obligations should have predefined, risk-based deadlines, escalation thresholds and approval requirements. Severity should consider impact and likelihood, including data sensitivity, internet exposure and exploitability. Owners must acknowledge critical obligations within a fixed timeframe, with non-confirmation triggering automatic escalation from the owner's manager to the CISO and then senior management.
If remediation cannot be completed on time, the owner must document a risk treatment: apply compensating controls, temporarily accept the residual risk, or escalate. Risk acceptance must record the risk scenario, existing controls, residual risk, owner and expiry date, and receive approval from an authorised risk owner at the appropriate level. This replaces the implicit, undocumented risk acceptance that allowed the ACIS vulnerability to persist.

Addresses: Section 3.4 (enforcement and escalation failure)
Responsible stakeholders: CISO, Enterprise Risk, Compliance and relevant business risk owners.
Priority: Immediate for critical vulnerabilities; subsequently extend the framework across broader compliance obligations.

4.4 Strengthen evidence-based closure

Equifax should prevent obligations from being closed solely on the basis of self-reported completion. Closure should require objective evidence appropriate to the control, such as vulnerability-rescan results, deployment records, test outputs or system logs. Evidence requirements should be defined when the task is created and retained in an auditable repository, with the following conditions apply:

- Asset- and component-scoped evidence. Evidence must identify the affected asset and demonstrate that the relevant component was checked. Reconciling scanner targets against the asset register detects omitted assets, but cannot establish that a scan examined the correct component or directory. Critical remediation should therefore require evidence of scan scope and configuration, supported by an authenticated scan or direct component-version check where appropriate.
- Independent evidence. Evidence should be produced by someone other than the person who performed the fix, applying segregation of duties so that no individual both performs and certifies a control.

Addresses: Section 3.5 (verification and evidence failure)

Responsible stakeholders: Application owners, Information Security, Compliance and Internal Audit.
Priority: Immediate, particularly for high-risk security remediation, with longer-term integration into automated evidence-collection systems.

4.5 Strengthen board and executive oversight

Equifax should provide the Board and senior management with regular reporting on material cyber and compliance risks, including overdue critical obligations, unresolved exceptions, risk acceptances and recurring control failures. The CISO should have sufficiently direct access to executive leadership and the Board to escalate material security concerns that can be raised without passing through management first. This supports the board's oversight duty and reduces the information asymmetry between management and the board that agency theory predicts.

Addresses: Section 3.1 (governance and oversight failure)
Responsible stakeholders: Board Risk/Audit Committee, CEO, CIO, CISO and Enterprise Risk.
Priority: Near term to establish clearer reporting and escalation arrangements, followed by longer-term dashboards and trend monitoring to support continuous oversight.

5. Existing Solutions and the Market Gap

Before designing a solution, we assessed whether commercial platforms already address the failures identified in Section 3. We compared PoliBridge with three categories of product: vulnerability response (ServiceNow), regulatory compliance management (Archer Evolv) and continuous compliance automation (Vanta and Drata), using vendors' public documentation.

Capability	**ServiceNow**	**Archer Evolv**	**Vanta / Drata**	**Is PoliBridge Filling This Gap?**
Ingest advisories / regulatory change	Yes (NVD, scanners)	Yes (AI horizon scanning)	Framework updates	Yes
Route tasks to owners	Yes, from CMDB ownership	Assigns obligation owners	Control owners	Yes
Continuous control monitoring	Remediation tracking	Partial	Yes	Yes
Requirement → control → evidence lineage	Partial	Yes	Yes	Yes
Exceptions / risk acceptance	Yes	Yes	Partial	Yes
Board and assessor reporting	Dashboards	Examiner-ready evidence	Partial (trust reports)	Per-obligation evidence for certification
Treats ownership and asset data as untrusted and tests it	No; relies on CMDB accuracy	Not advertised	Not advertised	Yes
Checks evidence covers the claim's asset and component	Rescan only	Not advertised	Pass/fail per test	Yes

Evidence expiry reopens dependent decisions	No	Not advertised	Historical results only	Yes
Canary tests of its own routing and escalation	No	No	No	Yes

Vulnerability Response assigns vulnerabilities to remediation teams based on configuration-item ownership in the CMDB, but its effectiveness depends on that data being accurate. ServiceNow's own guidance acknowledges that scanner and CMDB records often fail to match and recommends regular meetings between teams to resolve the gaps (ServiceNow, n.d.).

Archer Evolv Compliance maintains an obligations library with lineage from regulation to control to evidence (Archer, n.d.), so source-to-evidence traceability alone is not a differentiator. Vanta and Drata provide continuous automated control testing, link results to control owners and retain monitoring history (Drata, n.d.; Vanta, n.d.). Their tests, however, are largely pass/fail checks on integrated systems, not assessments of whether submitted evidence supports a specific remediation or applicability claim.

The public documentation reviewed does not establish whether competing products combine component-scoped evidence checks, expiry that reopens dependent decisions, and regular canary testing of routing and escalation. PoliBridge's proposed contribution is to integrate and demonstrate these mechanisms against the specific failures identified in the Equifax case.

6. PoliBridge: Technology-Enabled Solution

PoliBridge is a human-in-the-loop GRC platform built on one principle: every compliance status is a claim that must be proven, can expire, and is tested. A claim such as "ACIS is patched", "ACIS does not use Struts" is accepted only when evidence covering its scope supports it, remains valid only while that evidence is current, and is periodically challenged by the system itself. PoliBridge integrates with existing CMDB, identity, scanner and ticketing tools rather than replacing them.

Prototype scope: The PoliBridge demonstrator implements obligation intake, three-state applicability, owner routing and escalation, scope-checked evidence for both remediation and "Does Not Apply" claims, evidence expiry with reopening of dependent decisions, and canary tests of routing and escalation, using synthetic organisational data. CMDB, identity-directory, scanner and ticketing integrations are represented through test data or mocked interfaces. Production deployment would require source-specific connectors, secure enterprise infrastructure and data-quality validation.

6.1 Design Principle and Objectives

Objective	PoliBridge control	Equifax failure addressed
DO1 Traceability	Source-to-obligation-to-evidence audit trail	No closed-loop assurance
DO2 Accountability	Named owner, acknowledgement, fallback routing and escalation	Outdated mailing list; missed deadline not escalated
DO3 Risk oversight	Deterministic escalation and time-limited risk acceptance	No documented risk decision

DO4 Scoped evidence	Evidence must cover the claim's asset and component; negative claims need evidence	Clean scan accepted as "not affected"
DO5 Assurance over time	Claims expire with their evidence and reopen dependent decisions	Stale distribution list; expired certificate
DO6 Self-verification	Canary advisories test routing and escalation	Broken alert path went unnoticed

6.2 Users, decisions and ownerships

PoliBridge is a shared workflow across the three lines of defence. The Chief Compliance Officer is the business and process owner, Compliance Technology is the technical platform owner, and the CIO remains accountable for the asset register. Internal Audit provides independent assurance (Appendix D).
PoliBridge keeps four types of record: an obligation derived from an authoritative requirement; an asset task created to implement it; a data-quality finding raised when asset, component or ownership data is incomplete; and a claim, the status of any of these together with its evidence, scope and expiry.

6.3 Conceptual architecture and information flow

PoliBridge is organised in five layers:

1. Source layer: approved regulatory sources, security advisories, internal policies and contractual requirements.
2. Obligation intelligence layer: detects changes and converts source content into structured obligations linked to their origin.
3. Organisational context layer: maintains asset, component and ownership data, and detects gaps in it through reconciliation and attestation.
4. Decision and workflow layer: determines applicability and impact, routes tasks to named owners, provides guidance, and enforces acknowledgement, escalation and approval.
5. Assurance layer: verifies closure evidence, keeps the audit trail and reports to management and the Board.

In the prototype these inputs are synthetic records. Production deployment would integrate with Equifax's enterprise systems.

6.4 How Requirements Enter the System

PoliBridge does not depend on anyone recognising that an advisory affects their system. Security advisories from approved sources such as CISA, the National Vulnerability Database and software vendors are ingested automatically. Each advisory names the affected product and versions, so PoliBridge matches it against the component records of every asset in the register. Applicability is recorded in one of three states:

- Applies: the affected component is confirmed present, and an asset-level remediation task is created.
- Does Not Apply: verified component data shows the component is absent; the evidence and justification are recorded.
- Cannot Determine: component data is missing, stale or conflicting; a task is created for the owner and closure is blocked until it is resolved.

Missing information is treated as uncertainty, never as evidence of absence. Under this rule, an asset with no component record, as ACIS effectively was, becomes an owned task rather than being silently

skipped. Component data comes from software-composition analysis, software bills of materials in SPDX or CycloneDX formats (NTIA, 2021) and authenticated inventories, consistent with CIS Controls v8 Safeguards 2.1 and 2.4 (Center for Internet Security, 2021). Discovery reconciliation compares the register with network discovery, scanner target lists, DNS records and cloud inventories, raising findings for unregistered or unscanned assets (NIST, 2024).

Regulatory and policy sources are compared with their previous versions, and changed clauses become candidate obligations that Compliance or Legal must confirm, since materiality remains a human decision. For these obligations, retrieval-augmented generation (Lewis et al., 2020) drafts role-specific guidance grounded in the source clause, policies and asset context. Weakly grounded or conflicting outputs are withheld for review, and RAG cannot confirm applicability, accept risk or authorise closure.

6.5 Distinctive Feature 1: Scope-Checked Evidence

A claim is accepted only when its evidence covers the specific asset and component it concerns. Closure of a remediation task requires evidence that identifies the asset and affected component, was generated after the reported remediation, and uses an appropriate verification method such as an authenticated scan or direct component-version check. PoliBridge rejects incomplete, outdated or mismatched evidence, and the parent obligation closes only when every affected asset is remediated or covered by authorised, time-limited risk acceptance.

The approval a claim requires depends on whose knowledge it rests on. A claim within a single function, such as Information Security rating an advisory's severity or IT registering a new asset, needs one approver other than the person who performed the work. A claim that depends on both functions, such as "ACIS is patched", "ACIS does not use Struts" or "ACIS traffic is inspected", combines asset information held by IT with security judgement held by Information Security. PoliBridge therefore requires one sign-off from each function, each supported by that function's own evidence: the asset owner confirms the asset's component record, and Information Security confirms that verification covered that component. If the two disagree, or either side has no evidence, the claim reverts to Cannot Determine and both owners receive a task. Each of the three statuses Equifax relied on in 2017 (Section 1.1) was a claim of this kind: a security conclusion resting on asset information that no one responsible for the asset had confirmed. Restricting dual sign-off to these claims keeps the second review meaningful and limits the approval fatigue noted in Section 7.3.

Negative claims are held to the same standard. In March 2017, Equifax's effective conclusion was that ACIS was not affected, based on scans that never examined the Struts component (House Oversight Committee, 2018). Under PoliBridge, a scan whose recorded scope does not include the component cannot support a "Does Not Apply" claim: the evidence is rejected, the asset reverts to Cannot Determine and closure is blocked until component-specific evidence is supplied. Because this claim depends on both functions, the asset owner must also confirm the component record, and an empty record combined with a clean scan is treated as uncertainty, not agreement. The check depends on structured evidence fields (asset, component, scope, method, timestamp, submitter and reviewers); PoliBridge flags insufficient evidence rather than inferring safety from an uploaded report.

6.6 Distinctive Feature 2: Evidence Decay

Every claim carries an expiry tied to its evidence. Ownership attestations last six months and are invalidated earlier by a joiner, mover or leaver event or by the recipient rejecting a task; scan evidence

for critical internet-facing assets has a validity period set by policy; and monitoring claims expire with the certificates and configurations they rely on. When evidence expires, the claim reverts to Cannot Determine, and any decision that depended on it, such as an open task's routing, a risk acceptance or a board report item, is reopened and flagged to its owner.

Ownership is linked to a named individual's current corporate-directory identity, never an email address or distribution list. When an owner record is invalid or a task is rejected, the task is rerouted to the business-unit head and an ownership finding is raised, while the original deadline continues, so rejection cannot become an informal extension (Center for Internet Security, 2021; 23 NYCRR § 500.13). Under this feature, Equifax's distribution list and the expired inspection certificate would each have surfaced as a lapsed claim with a named owner, instead of failing without any alert.

6.7 Distinctive Feature 3: Canary Self-Tests

PoliBridge regularly tests its own process by injecting synthetic advisories, clearly marked as tests, against known assets. Canaries run on a schedule and after changes to ownership, assets or routing rules. Each canary checks that the task reaches a valid named owner, is acknowledged within the required time and escalates on schedule if it is not. A failed canary raises a finding assigned to the relevant owner and is reported separately from operational metrics. This applies the principle of chaos engineering, deliberately introducing faults to confirm that a system responds as designed, to the compliance process itself. A single canary directed at ACIS in early 2017 would have shown that alerts were not reaching its administrator. Canaries test whether routing and escalation work; they do not show that a real remediation succeeded, which remains the role of scoped evidence.

6.8 Impact Classification and Decision Rules

Consistent with NIST SP 800-30 (Joint Task Force Transformation Initiative, 2012), PoliBridge classifies obligations using regulatory significance, data sensitivity, system criticality, security severity, internet exposure, affected scope, third-party dependency and uncertainty. An obligation is High Impact when a decisive trigger is met, such as a critical exploitable vulnerability on an internet-facing asset, or when an approved combination of risk modifiers exceeds the escalation threshold. Missing information never lowers the classification. The ACIS vulnerability met several decisive triggers.

Decision rules are deterministic and approved by Compliance, Legal, Enterprise Risk and Information Security; where rules conflict, the more restrictive outcome applies until an authorised reviewer decides otherwise. Key rules include escalation of unacknowledged High Impact tasks to the owner's manager at four hours and the CISO at eight hours, escalation of missed deadlines to the risk owner and the next board risk report, and time-limited risk acceptance that reopens on expiry. The full criteria and rules are in Appendices B and C.

6.9 Replaying March 2017

Appendix A illustrates how PoliBridge could have exposed different failures in March 2017. Assuming ACIS was discovered and the advisory ingested, missing component data would have produced Cannot Determine and an owned investigation task. Invalid ownership records would have triggered fallback routing, while unacknowledged or overdue tasks would have escalated. Scope checks would have rejected scan evidence that failed to demonstrate coverage of the relevant component.

A canary could have revealed a broken routing or escalation path, provided its expected recipient was independently validated. Separately, certificate-linked expiry could have flagged that traffic inspection was no longer supported by valid evidence. Neither check alone would establish that Struts remained unpatched. Together, these controls could have made unresolved vulnerability, ownership and monitoring risks visible before exploitation, subject to adequate input data and timely human action. The replay illustrates expected behaviour rather than demonstrating that PoliBridge would necessarily have prevented the breach.

6.10 Value to Equifax

PoliBridge complements rather than duplicates Equifax's post-breach investments. Section 3.7 found that Equifax's disclosures emphasise aggregate measures without showing that individual obligations are traceable to accountable closure; PoliBridge supplies this obligation-level assurance. It is particularly relevant to the 2019 FTC settlement, which requires annual board certification of compliance and biennial independent assessments (FTC, 2019). Directors who must personally certify compliance need evidence they can verify, not only metrics reported by management. SEC rules also require annual disclosure of how the board oversees cybersecurity risk (Securities and Exchange Commission [SEC], 2023). A record of scoped, time-limited and tested claims gives the Board, assessors and regulators verifiable evidence that controls operate in practice, reducing the information asymmetry identified in Section 3.1.

7. Evaluation, Feasibility, and Limitations

7.1 Evaluating Effectiveness

The prototype will be tested against synthetic scenarios, each with a defined input, context and expected outcome. A scenario passes only if the system reaches the expected outcome and records a complete audit trail (DO1).

1. March 2017 replay: Struts advisory, ACIS with no component data and a lapsed owner. Expected: Cannot Determine, fallback routing, escalation and blocked closure (all objectives).
2. Unacknowledged or rejected task: escalation at four and eight hours, or immediate rerouting with the deadline still running (DO2).
3. Missed deadline or expired risk acceptance: escalation to the risk owner, or automatic reopening (DO3).
4. Scan evidence that omits the affected component: evidence rejected and the asset reverts to Cannot Determine (DO4).
5. Irrelevant technology with verified component data: Does Not Apply with recorded justification and no task, testing that the design does not generate unnecessary alerts (DO4).
6. Ownership attestation or certificate expiry: claim reverts to Cannot Determine and dependent decisions reopen (DO5).
7. Canary against an asset whose owner record routes to a distribution list: routing failure detected and a finding raised (DO6).

Following testing, PoliBridge would be piloted on critical internet-facing assets, with baselines taken from existing tools. Metrics would include correct first-time routing rate and time to acknowledge (DO2), the share of closures supported by scoped, independently verified evidence, with a target of 100% (DO4), the share of claims on critical assets with current evidence (DO5) and the canary pass

rate (DO6). Because metrics measure activity rather than whether controls catch failures, Internal Audit would also run its own seeded-fault tests, independent of the canaries, to check that PoliBridge detects an Equifax-type failure.

7.2 Feasibility

Technical: PoliBridge uses established components: a rule engine, a relational database for claims and evidence, and API integrations with the CMDB, identity directory, scanners and ticketing tools. LLM use is confined to the regulatory intake path, limiting cost and the scope for model error. Legacy systems without SBOMs are handled by the Cannot Determine state rather than by assumption.

Operational: on a legacy estate, initial reconciliation and Cannot Determine results could produce more tasks than owners can absorb. A phased rollout starting with critical internet-facing assets, consistent with the immediate priorities in Section 4, mitigates this.

Organisational: PoliBridge depends on CCO sponsorship, CIO accountability for the asset register and owners treating attestation as a real review. Embedding tasks in existing ticketing tools reduces resistance, and Internal Audit sampling deters box-ticking.

Economic: costs include integration, licensing, modest LLM usage and staff time for attestation and review, partly offset by reusing existing tools and reducing manual audit effort. These should be weighed against Equifax's settlement of at least US$575 million (FTC, 2019).

7.3 Limitations and unintended consequences

- Invisible assets. An asset missed by every discovery source never enters the workflow. Several independent sources make this unlikely for internet-facing systems but cannot rule it out for shadow IT.
- Human resolution of uncertainty. PoliBridge flags Cannot Determine and demands evidence, but someone must still produce it through a scan, SBOM or version check.
- Verification limits. Scanners can produce false negatives, version records can be wrong and reviewers can accept weak evidence. Scoped evidence and independent review reduce these risks without eliminating them.
- Canary limits. Canaries test routing and escalation, not remediation, and owners who recognise test advisories may treat them differently. Running them unannounced, with Internal Audit oversight, reduces this risk.
- Alert fatigue and rubber-stamping. The fail-safe design favours over-alerting, and owners may attest without real review. Phased rollout, risk-based thresholds and audit sampling address these over time.
- Automation bias. Users may trust classifications and generated guidance more than they should. Human review remains mandatory for high-impact, uncertain and exceptional cases.
- Market comparison. Our current comparison relies on public vendor documentation, vendors may have capabilities they do not publicise.

PoliBridge is decision support and control orchestration, not a substitute for accountable governance, professional judgement or independent assurance.

8. Future Trends and Conclusion

8.1 Future regulatory/GRC trends

Three developments suggest that the control gaps exposed by Equifax are increasingly becoming explicit regulatory expectations rather than matters of internal discretion.

First, software transparency is becoming mandatory. Equifax's failure to identify that ACIS ran Apache Struts reflected the absence of reliable component data (House Oversight Committee, 2018). The EU Cyber Resilience Act addresses this for software manufacturers: vulnerability reporting obligations apply from September 2026, and from December 2027 manufacturers must maintain an up-to-date, machine-readable SBOM for each product (Regulation (EU) 2024/2847, 2024). As supplier SBOMs become routine, the "component data unverified" state that PoliBridge treats as a legacy exception should become progressively rarer.

Second, regulators are demanding faster escalation and visible board oversight. US public companies, including Equifax, must now report material cybersecurity incidents within four business days of determining materiality, and must disclose annually how the board oversees cybersecurity risk and how management assesses and manages it (Securities and Exchange Commission [SEC], 2023). Together with the FTC's 2023 breach-notification amendment (Federal Trade Commission, 2024), this makes the filtered, slow-moving information flow seen at Equifax a direct compliance risk, not only a governance weakness.

Third, GRC is becoming continuous and increasingly AI-driven. Control evidence is shifting from periodic audits to ongoing collection, and agentic systems may soon retrieve requirements, propose applicability decisions and assign tasks. This raises the importance of provenance and human oversight, consistent with the emphasis on accountability and transparency in the NIST AI Risk Management Framework (National Institute of Standards and Technology [NIST], 2023): future systems must show which source supported each decision, who approved it and what evidence confirmed closure.

Automation alone is therefore insufficient. Faster detection and AI-assisted interpretation reduce risk only when combined with accountable ownership, controlled escalation and evidence that is kept current, otherwise they reproduce Equifax's failures at greater speed and scale.

8.2 Conclusion

The Equifax breach was not caused by a lack of awareness. The vulnerability was disclosed, the advisory was received and a 48-hour patching policy existed (House Oversight Committee, 2018). It occurred because that requirement never became accountable action, and because Equifax relied on statuses that had silently become false. The alert went to an outdated distribution list. A scan that never reached the Struts component was taken as proof that ACIS was unaffected. An expired certificate left monitoring blind. Equifax's post-breach reforms have strengthened its governance structure and technical capability, but its disclosures show limited evidence that individual obligations are traceable to accountable closure.

Existing platforms already provide routing, monitoring and traceability. PoliBridge's contribution is to treat each status as a claim that must be supported by scoped evidence, expires when that evidence

ages, and is tested by the system itself. The March 2017 replay illustrates how this could have made Equifax's failures visible before exploitation. Whether it would have prevented the breach depends on accurate data and timely human action.

For boards, oversight depends on whether the information reaching them can be verified, not only on how often they are briefed. For compliance and security functions, a policy is only as effective as current evidence that it operated. Technology can make failures visible and owned, but deciding which risks to accept, and answering for those decisions, remains a human responsibility.

References

Archer. (n.d.). *Archer Evolv Compliance*. Retrieved October 2026, from https://www.archerirm.com/evolv-compliance

Center for Internet Security. (2021). *CIS Critical Security Controls, Version 8*. Center for Internet Security.
Drata. (n.d.). *Monitoring and tests*. Retrieved October 2026, from https://drata.com/products/compliance/monitoring-and-tests

Equifax Inc. (2017, September 15). *Equifax releases details on cybersecurity incident, announces personnel changes*. Equifax Investor Relations.

Equifax Inc. (2025). *2025 security annual report*. Equifax Inc.

Equifax Inc. (2026, August 24). *Equifax AI-enabled security: Transforming the organization's cyber defenses*. Equifax Inc.

Federal Trade Commission. (2019, July 22). *Equifax to pay $575 million as part of settlement with FTC, CFPB, and states related to 2017 data breach*. Federal Trade Commission.

Information Commissioner's Office. (2019). *Information Commissioner's annual report and financial statements 2018–19*. Information Commissioner's Office.

Joint Task Force Transformation Initiative. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1

Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Küttler, H., Lewis, M., Yih, W., Rocktäschel, T., Riedel, S., & Kiela, D. (2020). Retrieval-augmented generation for knowledge-intensive NLP tasks. *Advances in Neural Information Processing Systems, 33*, 9459–9474.

National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)* (NIST AI 100-1). https://doi.org/10.6028/NIST.AI.100-1

National Institute of Standards and Technology. (2024). *The NIST cybersecurity framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

National Telecommunications and Information Administration. (2021). *The minimum elements for a software bill of materials (SBOM)*. U.S. Department of Commerce.

Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). (2024). *Official Journal of the European Union*, L 2024/2847. https://eur-lex.europa.eu/eli/reg/2024/2847/oj

Securities and Exchange Commission. (2023). *Cybersecurity risk management, strategy, governance, and incident disclosure* (Release Nos. 33-11216; 34-97989).

https://www.sec.gov/files/rules/final/2023/33-11216.pdf

ServiceNow. (n.d.). *Get the most out of Vulnerability Response by leveraging CMDB*. ServiceNow Community. Retrieved October 2026, from https://www.servicenow.com/community/secops-articles/get-the-most-out-of-vulnerability-response-by-leveraging/ta-p/2342563

U.S. Government Accountability Office. (2018). *Data protection: Actions taken by Equifax and federal agencies in response to the 2017 breach* (GAO-18-559). U.S. Government Accountability Office.

U.S. House of Representatives, Committee on Oversight and Government Reform. (2018). *The Equifax data breach: Majority staff report*. U.S. House of Representatives.

U.S. Senate, Permanent Subcommittee on Investigations. (2019). *How Equifax neglected cybersecurity and suffered a devastating data breach: Staff report*. U.S. Senate Committee on Homeland Security and Governmental Affairs.

Vanta. (n.d.). *Vanta: Automated security and compliance*. Retrieved October 2026, from https://www.vanta.com

Center for Internet Security. (2021). CIS critical security controls (Version 8). Center for Internet Security.

Committee of Sponsoring Organizations of the Treadway Commission. (2013). Internal Control – Integrated Framework. COSO.

Institute of Internal Auditors. (2020). The IIA's Three Lines Model: An update to the Three Lines of Defense. The Institute of Internal Auditors. https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model/

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce. https://doi.org/10.6028/NIST.CSWP.29

U.S. Government Accountability Office. (2018). Data protection: Actions taken by Equifax and federal agencies in response to the 2017 breach (GAO-18-559). U.S. Government Accountability Office. https://www.gao.gov/assets/gao-18-559.pdf

Appendices

Appendix A — March 2017 Replay Through PoliBridge

Date	What happened at Equifax	What PoliBridge would do
Before March	Distribution list excluded the ACIS administrator; nobody knew	A routine canary against ACIS fails at routing; an ownership finding is raised for the business-unit head.
8 March	US-CERT notifies Equifax of CVE-2017-5638	Advisory ingested automatically and matched against every asset. ACIS is marked Applies if Struts is recorded, otherwise Cannot Determine; it cannot be silently excluded. Classified High Impact (critical severity, internet exposure, personal data).
9 March	Alert emailed to an outdated distribution list	Task routed to the ACIS owner's directory identity; if that record has lapsed, to the business-unit head.
9 March (+4h, +8h)	No confirmation of receipt required	Unacknowledged task escalates to the owner's manager at four hours and the CISO at eight hours.
~11 March	48-hour deadline passes; no escalation	Escalation to the risk owner and senior management; item appears in board risk reporting unless time-limited risk acceptance is approved.
15 March	Scans miss the Struts component; ACIS treated as unaffected	Scan evidence rejected because its scope does not cover the Struts component; task stays open and ACIS remains Cannot Determine or Applies.
Before 13 May	Inspection certificate has expired; nobody notices	The "ACIS traffic is inspected" claim lapses with the certificate and is flagged to its owner.
13 May	Attackers exploit the unpatched portal	The open ACIS task would have been visible to the CISO and senior management for about two months.

Appendix B — Impact Classification Criteria

Criterion	Assessment considerations	Indicates High Impact when
Regulatory significance	Whether non-compliance could trigger mandatory reporting, enforcement, penalties or other legal consequences	Non-compliance could require breach notification or expose the organisation to enforcement action
Data sensitivity	Whether the system processes personal, financial or protected information	The system stores or processes personal or financial data classified Confidential or above
System criticality	Importance of the system to essential operations	The system is designated critical or supports a customer-facing service
Security severity	Severity and exploitability of the vulnerability	CVSS base score of 9.0 or above, or listed in CISA's Known Exploited Vulnerabilities catalogue

Internet exposure	Whether the asset is reachable from the internet	Risk modifier; decisive when combined with critical exploitability
Affected scope	Number of systems, business units, customers or jurisdictions affected	Impact spans several business units or jurisdictions, or exceeds a customer-volume threshold
Third-party dependency	Supplier access to systems and data and importance to critical services	The supplier has access to sensitive data or supports a critical service (NIST, 2024)
Uncertainty	Whether information is incomplete, conflicting or insufficient	Not a severity criterion: any criterion that cannot be assessed triggers human review and never lowers the classification

Appendix C — Decision Rules

#	Decision rule	Governance outcome
A. Applicability		
A1	Affected component confirmed present on an asset	Applies: create a remediation task for that asset
A2	Component confirmed absent in verified component data	Does not apply: record the justification and data source; no task created
A3	Component data missing, unverified or stale	Cannot determine: route to the asset owner for confirmation; never marked non-applicable automatically
A4	Regulatory interpretation low-confidence, or sources conflict	Suspend generated guidance; route to Compliance or Legal for interpretation
B. Asset and ownership integrity		
B1	Internet-facing asset found by discovery but not in the register	Classify as High Impact; raise a registration-and-ownership obligation for the responsible business unit
B2	Registered asset absent from scanner target lists	Raise a coverage-gap obligation for Information Security
B3	Ownership attestation expired, or owner flagged as a leaver or mover	Treat the owner as invalid; route tasks to the business-unit head and raise a reassignment obligation
B4	Recipient rejects a task as outside their responsibility	Reroute immediately; the deadline continues to run; raise an ownership-correction obligation
C. Impact classification		
C1	Critical or high-severity exploitable vulnerability on an internet-facing asset	Classify as High Impact; fast path: route to the owner immediately, with Security review running in parallel rather than as a gate

C2	Critical system affected	Classify as High Impact; require Security and system-owner review
C3	Sensitive data affected, with material security impact	Classify as High Impact; require Security and Compliance approval
C4	Regulatory reporting or legal obligation triggered	Require Legal or Compliance review before closure
C5	Critical third-party dependency affected	Escalate to the vendor-risk owner and the relevant business owner
C6	Classification borderline or criteria conflict	Route to the accountable risk owner for determination
D. Acknowledgement and escalation		
D1	High Impact task not acknowledged within 4 hours	Escalate to the owner's manager
D2	High Impact task not acknowledged within 8 hours	Escalate to the CISO
D3	Remediation deadline missed (48 hours for critical vulnerabilities)	Escalate to the accountable risk owner and senior management; include in the next board risk report
D4	Exception or delayed remediation requested	Require documented risk acceptance by an authorised risk owner, with rationale, compensating controls and expiry date
D5	Risk acceptance reaches its expiry date	Reopen the task and notify the risk owner
E. Evidence and closure		
E1	Evidence does not identify the target asset	Reject the evidence; the task remains open
E2	Evidence predates the reported remediation	Reject the evidence; request a fresh rescan or version check
E3	Verifier is the person who performed the remediation	Block approval; route to an independent reviewer
E4	Required evidence incomplete	Prevent closure until the evidence is submitted and verified
E5	Any asset remains "cannot determine" for an obligation	Block obligation closure until resolved
F. Evidence decay and self-testing		
F1	Evidence supporting a claim reaches its expiry	Claim reverts to Cannot Determine; notify its owner
F2	A claim that other decisions depend on reverts	Reopen dependent tasks, risk acceptances and report items

F3	Canary not routed to a valid named owner, or not escalated on schedule	Raise a routing finding for the business-unit head; report separately from operational metrics

Appendix D — RACI / approval matrix

Activity	CCO	Compliance Technology	CIO	CISO	Asset owner	Internal Audit
Approved source registry and decision rules	A	R	C	C	I	I
Asset register and ownership data	I	C	A	C	R	I
Remediation and evidence submission	I	I	C	A	R	I
Independent evidence review	I	I	I	A	C	C
Risk acceptance	C	I	C	R	C	I
Canary testing	A	R	C	C	I	C
Assurance and seeded-fault testing	I	C	I	I	I	A/R

R = Responsible, A = Accountable, C = Consulted, I = Informed. The accountable risk owner for risk acceptance is set by Enterprise Risk according to the risk level.

Appendix E — Approved-Source Registry Schema

Appendix F — RAG Prompt and Output Schema

Appendix G — Prototype Screenshots

Appendix H — Test Scenarios and Results

Appendix I — AI-use acknowledgement